

Explainable AI-Based Android Application Privacy Risk Assessment and Decision Support System

1. Introduction

Mobile applications frequently request access to sensitive resources such as location, contacts, messages, device information, and network services. Although application stores provide permission and privacy-related information, this information is often technical and difficult for ordinary users to interpret when deciding whether an application should be installed.

This project proposes an **Explainable AI (XAI)-based Android Privacy Risk Assessment and Decision Support System**. The system analyzes behavioral features extracted from Android applications, predicts their privacy risk, identifies the major factors responsible for the prediction, and converts those technical factors into concise, user-friendly explanations.

The objective is not simply to classify applications as malicious or benign, but to help users understand **why an application may present a privacy risk and make a more informed installation decision**.

2. Problem Statement

Existing application stores provide users with information such as requested permissions and data-safety declarations. However, users may have difficulty understanding:

- Why an application requires particular permissions.
- Which behaviors contribute most to its privacy risk.
- What the technical behavior could mean for the user's privacy.
- Whether the requested access appears excessive for the application's purpose.

A system is therefore needed that can transform technical application behavior into an understandable **privacy risk assessment and explanation**.

3. Research Objective

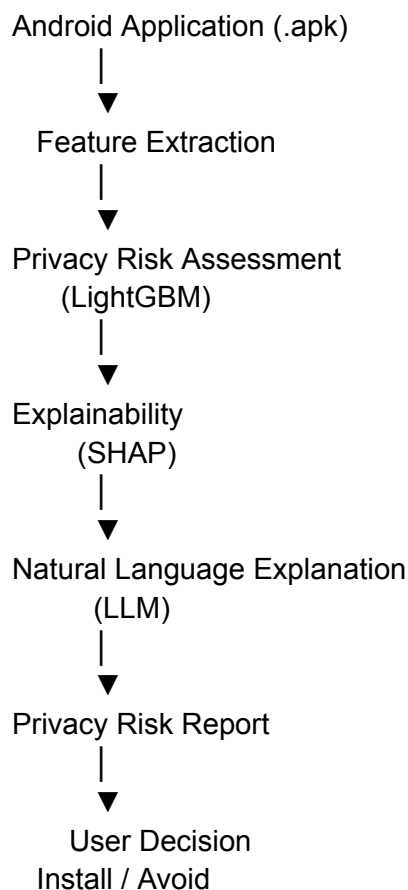
The primary objective is to develop an explainable AI system that:

1. Extracts relevant behavioral features from Android applications.
2. Predicts the application's privacy risk level.
3. Identifies the features that contribute most to the prediction.
4. Converts these technical factors into understandable natural-language explanations.
5. Presents the results through a simple decision-support interface before installation.

The system will focus on **privacy risk assessment and explanation**, rather than claiming to provide definitive malware detection.

4. Proposed System

The proposed system consists of five main stages:



The system will use the **LAMDA Android application dataset** for model development and evaluation. The dataset provides structured application-level behavioral features that can be used to train the machine-learning model. The same feature representation will be maintained when extracting features from an application during system use.

5. Dataset

LAMDA Dataset

The **LAMDA Android application dataset** will be used as the primary dataset for developing the risk-assessment model.

The dataset contains structured Android application characteristics such as permissions, API-related behaviors, and other application features. Each application can therefore be represented as a feature vector suitable for machine-learning algorithms.

For example:

Feature	Value
READ_CONTACTS	1
ACCESS_FINE_LOCATION	1
SEND_SMS	0
RECEIVE_BOOT_COMPLETED	1
Tracking/Advertising SDK	1

The dataset will be used during the **training phase**, while an actual APK will provide the input features during system operation.

Therefore:

LAMDA Dataset



Train Risk Model



Trained Model

Actual APK



Extract Same Features



Trained Model

This separation makes the proposed architecture more representative of a real-world application.

6. Risk Assessment Model

A **LightGBM** classifier will be used because the application representation consists primarily of high-dimensional and potentially sparse behavioral features.

The model will estimate a privacy risk category such as:

- **Low Risk**
- **Medium Risk**
- **High Risk**

The risk level should be interpreted as an **AI-based privacy risk assessment**, not as a definitive statement that an application is malicious.

The model will be evaluated using standard classification metrics such as:

- Accuracy
- Precision
- Recall
- F1-score

Where appropriate, class imbalance will also be considered during training.

7. Explainable AI Using SHAP

A major component of the project is explainability.

A prediction such as:

High Privacy Risk

is not sufficient for a user.

Therefore, **SHAP (SHapley Additive exPlanations)** will be used to identify which application features contributed most strongly to the prediction.

For example:

Predicted Risk: HIGH

Major contributing factors:

1. READ_CONTACTS

- 2. ACCESS_FINE_LOCATION
- 3. Advertising/Tracking SDK

This allows the system to answer:

"Why did the system consider this application risky?"

rather than simply providing a risk label.

8. LLM-Based Explanation

The SHAP output is still technical and may not be meaningful to ordinary users.

An LLM will therefore translate the important technical factors into concise natural-language explanations.

For example:

Technical Output

Risk: High

Top contributors:

READ_CONTACTS

ACCESS_FINE_LOCATION

Advertising SDK

User-Facing Output

High Privacy Risk

This application requests access to your contacts and precise location and contains tracking-related components. These permissions may expose personal information that is not obviously necessary for the application's primary function.

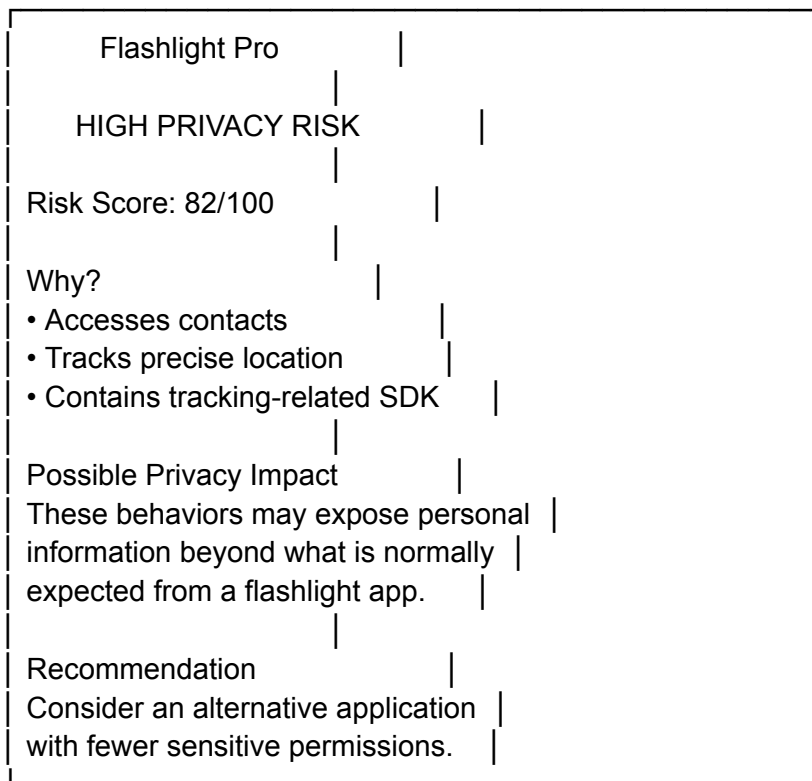
The LLM will operate under a controlled prompt that restricts the output length and requires it to remain grounded in the features identified by the model and SHAP.

The LLM will **not independently determine the risk**. The risk assessment comes from the trained model, while the LLM acts primarily as a natural-language explanation layer.

9. Privacy Risk Report

The final interface will present the assessment as a simple privacy report.

Example:



The interface will therefore communicate four things:

Risk → Reasons → Potential Impact → Recommendation

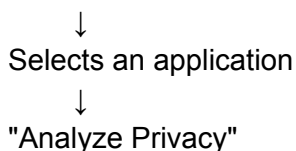
This structure is intended to support an actual user decision rather than merely display an ML prediction.

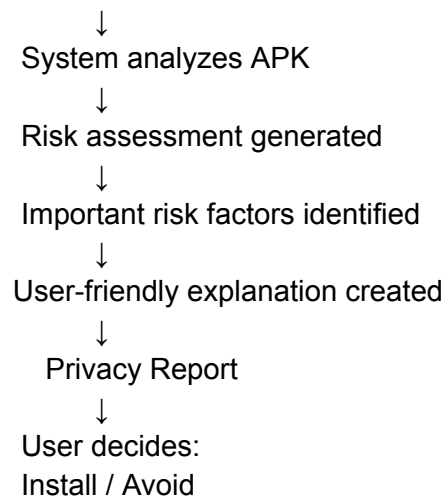
10. Real-World Use Case

The proposed system can be integrated conceptually into an application marketplace, privacy assistant, or mobile security tool.

Use Case

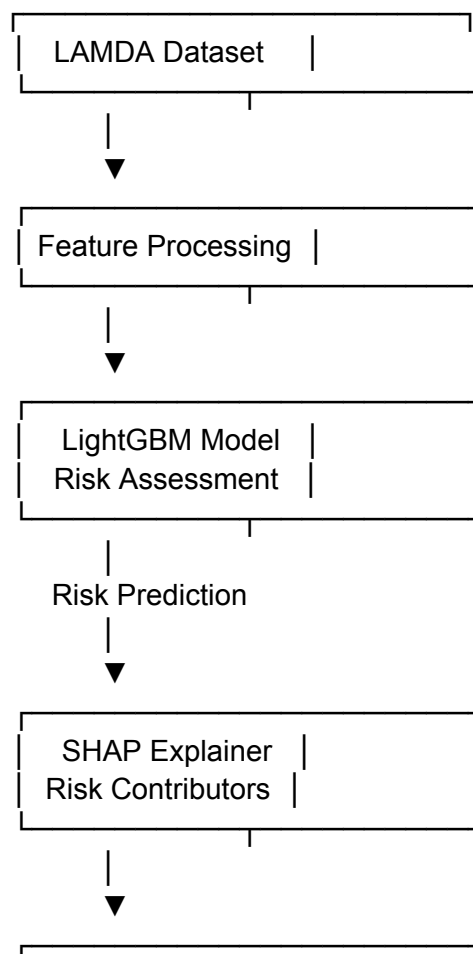
User searches for an Android application

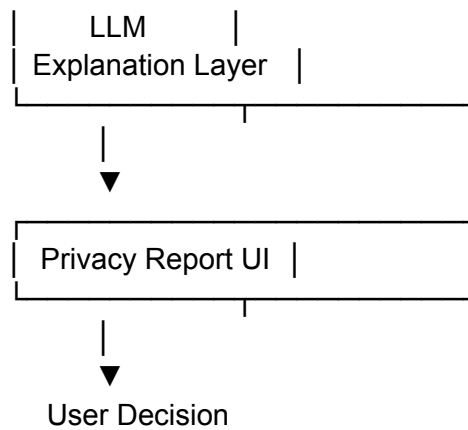




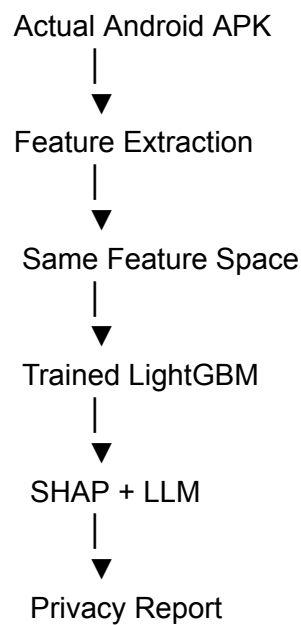
The system therefore acts as a **decision-support layer between technical application analysis and the end user**.

11. System Architecture





During real system operation, the LAMDA dataset is not directly shown to the user. Instead:



12. HCI Evaluation

The project will also evaluate whether presenting AI-generated explanations improves users' understanding of application privacy risks.

A controlled interactive prototype will be developed using a set of pre-selected application profiles. The applications will represent different privacy-risk scenarios.

For example:

Application	Risk	Example Behavior
-------------	------	------------------

Calculator	Low	Few sensitive permissions
Fitness App	Medium	Location access and tracking
Flashlight	High	Contacts, location and tracking

The explanations for these applications can be generated in advance to ensure that every participant evaluates the same scenarios.

This controlled approach avoids differences between participants caused by arbitrary APKs and ensures a consistent experimental environment.

13. HCI User Study

A possible between-subjects evaluation will compare two interfaces:

Control Group

Users receive conventional technical privacy information such as:

"This application requests access to Contacts and Location."

Experimental Group

Users receive the proposed AI-generated explanation:

"This application requests access to your contacts and precise location. These permissions may expose personal information beyond what is normally required for this type of application."

Participants will then be asked to make an installation decision and answer questions measuring their understanding of the application's privacy behavior.

The study can therefore investigate whether **explainable privacy information improves user comprehension and decision-making**.

14. Evaluation

The project will evaluate the system at two levels.

Machine Learning Evaluation

The risk model will be evaluated using:

- Accuracy
- Precision
- Recall
- F1-score
- Confusion matrix

User Evaluation

The HCI component will examine:

- User understanding of privacy risks
 - Ability to identify risky application behaviors
 - Confidence in the installation decision
 - Time required to understand the privacy information
 - User preference between technical and AI-explained information
-

15. Expected Contribution

The project aims to provide three main contributions:

1. Explainable Privacy Risk Assessment

Rather than simply classifying an application, the system identifies the behavioral factors responsible for the assessment.

2. Human-Understandable Privacy Information

Technical application behaviors are transformed into concise explanations that ordinary users can understand.

3. Privacy Decision Support

The system presents the assessment in a form intended to help users make an informed decision before installing an application.

16. Scope and Limitations

To keep the project achievable within the available timeframe, the following scope will be maintained:

- Focus on Android applications.
- Use the LAMDA dataset for model development.
- Use static application features rather than full dynamic execution analysis.
- Use LightGBM for risk prediction.
- Use SHAP for model explanation.
- Use an LLM only for translating structured explanations into natural language.
- Evaluate the interface using a controlled set of application scenarios.
- The system will provide **privacy risk assessment**, not guarantee that an application is malicious or safe.

Real-time analysis of arbitrary applications, large-scale deployment, and comprehensive dynamic malware analysis will remain outside the initial project scope.

17. Proposed Research Workflow

Literature Review



Dataset Preparation



Feature Engineering



LightGBM Model Training



Model Evaluation



SHAP Explainability



LLM Explanation Generation



APK Feature Extraction Prototype



Privacy Report Interface



HCI User Study



Analysis of Results



Final Evaluation

18. Proposed Title

Primary Title

Explainable AI-Based Android Application Privacy Risk Assessment and Decision Support System

Alternative

An Explainable AI Framework for Android Application Privacy Risk Assessment and User Decision Support

The first title is preferable because it clearly communicates the three major components of the project: **AI-based assessment, explainability, and user decision support**.

WORK DISTRIBUTION